BurgerFlow

DOCUMENTO TÉCNICO · ANÁLISIS DE SISTEMA

Análisis de entidad, operaciones CRUD y seguridad

Evaluación del prototipo de gestión para restaurante, con énfasis en pedidos, permisos y protección de datos.

Hallazgo de alcance
El workspace contiene una maqueta navegable en HTML y JavaScript, no una aplicación React. Las interacciones no representan persistencia ni autorización efectiva.



Elaborado por

Victor Vargas

Análisis basado en los archivos disponibles en el workspace
28 de octubre de 2026

01 Contexto y entidad principal

Descripción del sistema

BurgerFlow representa la gestión operativa de un restaurante y el flujo de compra de sus productos. Incluye vistas de panel, POS, menú de clientes, carrito, inventario, cocina y reparto, conectadas mediante enlaces entre archivos HTML. Las pantallas muestran pedidos, productos, ventas y estados de preparación, pero la mayoría de sus datos son estáticos o se modifican solo en el DOM del navegador. No se encontró conexión con una base de datos ni autenticación real.

Alcance y limitaciones de la inspección

No se encontraron `package.json`, fuentes `.jsx` / `.tsx`, modelos tipados ni rutas de React. El README describe una maqueta que se abre desde `index.html` sin servidor. Los campos que siguen son inferidos de la interfaz, no de un modelo persistente. No se observó cliente HTTP, endpoint ni conexión a base de datos.

Evidencia: mockup\README.md, líneas 1–7.

Entidad seleccionada: Pedido

Pedido articula el recorrido funcional central: el cliente configura productos y revisa el carrito; el POS representa la venta; cocina presenta su preparación; delivery muestra su despacho. La lámina de arquitectura describe el flujo menú → personalización → carrito → orden. Es una elección analítica, no una entidad declarada formalmente en código.

Evidencia: mockup\arquitectura-componentes.svg, líneas 54–70; checkout: mockup\carrito_y_confirmaci_n\code.html, líneas 145–254.

01 · Menú — Selección de productos › **02 · Personalización** — Tamaño, extras y cantidad › **03 · Carrito** — Resumen e importes › **04 · Operación** — Cocina y delivery

Datos de demostración: los nombres y direcciones visibles en delivery no pueden considerarse reales ni ficticios de forma concluyente. Deben verificarse como sintéticos antes de publicar la maqueta.

02 Atributos inferidos de Pedido

No existe un tipo o modelo explícito de pedido. Restricciones no definidas se señalan como inferidas o no especificadas.

Campo	Tipo de dato	Descripción	Obligatorio	Sensible
`codigo`	Cadena (inferido)	Identificador visible, p. ej. #BF-1024 o #ORD-8492.	Sí en pantalla; restricción no especificada.	No
`items`	Lista de LineaPedido (inferido)	Productos del pedido y cantidades.	Sí para compra; validación no especificada.	No
`items.producto`	Cadena (inferido)	Nombre del producto solicitado.	Sí en ejemplos.	No
`items.cantidad`	Entero (inferido)	Unidades por artículo; el selector tiene mínimo visual de 1.	Sí en ejemplos; validación integral no especificada.	No
`items.personalizacion`	Lista/cadena (inferido)	Tamaño, extras o ingredientes que se agregan o retiran.	No; depende de la selección.	Posibles preferencias alimentarias; sensibilidad no especificada.
`items.precioUnitario`	Decimal (inferido)	Precio mostrado por producto.	No especificado en modelo.	Comercial
`tipo`	Cadena/enum (inferido)	Comer en local, para llevar o delivery.	Sí en flujo; restricción no especificada.	No
`mesa`	Cadena/número (inferido)	Mesa vinculada a consumo en el local.	Condicional; validación no especificada.	No
`estado`	Cadena/enum (inferido)	Nuevo, en preparación, listo o en camino.	Sí para seguimiento; transiciones no especificadas.	No
`fechaHora`	Fecha/hora (inferido)	Hora o antigüedad mostrada del pedido.	No especificado.	No
`nombreCliente`	Cadena (inferido)	Nombre que aparece para una entrega.	No especificado.	Sí: dato personal identificable.
`direccionEntrega`	Cadena (inferido)	Destino del pedido a domicilio.	Condicional a delivery.	Sí: dato personal y ubicación.
`repartidorAsignado`	Cadena (inferido)	Nombre o identificador del repartidor asignado.	Condicional a delivery.	Sí: identifica a una persona trabajadora.
`tiempoEstimadoEntrega`	Duración/fecha-hora (inferido)	Tiempo estimado mostrado en seguimiento.	No especificado; puede estar ausente.	No
`canalOrigen`	Cadena (inferido)	Canal/plataforma de origen del pedido, p. ej. UberEats o DoorDash.	No especificado.	Comercial
`metodoPago`	Cadena/enum (inferido)	Efectivo, tarjeta o QR. No se muestran credenciales de tarjeta.	Sí en control requerido del checkout.	No por sí solo; no hay credenciales visibles.
`estadoPago`	Cadena/enum (inferido)	Pagado en línea o pago contra entrega.	No especificado en el modelo.	Sí: información transaccional.
`subtotal, impuesto, cargoServicio, total`	Decimal (inferido)	Importes presentados en el resumen del carrito.	No especificado como modelo.	Sí: información transaccional.



03 Matriz CRUD y permisos

Roles mostrados: Jefe/Admin, Cajero, Cocinero, Delivery y Cliente. Son etiquetas que conducen a pantallas, no roles autenticados ni permisos efectivos. Las autorizaciones aquí descritas son una **propuesta** para un backend futuro.

Evidencia: mockup\index.html, líneas 136–143.

Entidad o dato	Crear	Leer	Actualizar	Eliminar
Pedido y artículos	Cliente (pedido propio); Cajero (venta asistida).	Cliente (propio); Cajero/Admin; Cocinero (cola); Delivery (solo asignados).	Cajero antes de enviar; Cocinero solo estados de preparación; Delivery solo estados de reparto asignado; Admin.	Admin con cancelación auditada; Cliente antes de confirmar.
Nombre y dirección	Cliente al solicitar delivery.	Cliente (propio); Delivery asignado; Cajero solo si necesario; Admin.	Cliente antes de confirmar; Admin con motivo y auditoría.	Admin según retención; preferir anonimización cuando proceda.
Repartidor y estimación	Admin/operación asigna; sistema estima.	Repartidor asignado y personal que lo requiera.	Admin/operación reasigna; repartidor actualiza hitos permitidos.	Admin desasigna o cancela; conservar auditoría.
Estado	Sistema al crear el pedido.	Cliente (propio); personal según su tarea.	Cocinero: preparación/listo; Delivery: despacho asignado; Admin corrige con auditoría.	No borrar como operación ordinaria; cancelar mediante flujo auditado.
Pago e importes	Sistema calcula; Cliente/Cajero selecciona método.	Cliente (propio), Cajero y Admin; no requiere acceso de Cocina.	Recalcular en servidor; conciliar estado por personal autorizado y auditado.	No eliminar registro financiero aislado; política de retención.

Operaciones visibles y estado real

Crear pedido (simulado) En POS, un producto se añade como línea al pedido visible en el DOM. El checkout muestra un modal y comprueba artículos y método de pago, pero no registra la orden. La personalización sí se guarda en `sessionStorage`.

Crear inventario El formulario agrega una fila solo al DOM; no persiste.

Leer Los pedidos, productos e importes provienen del HTML estático; no se consultan registros.

Actualizar Cantidades y estados pueden cambiar en el DOM. Editar inventario solo muestra un mensaje; no actualiza la fila.

Eliminar El manejador elimina del DOM la fila, tarjeta o artículo; no elimina datos persistentes. No hay CRUD con autorización real.

Evidencia: POS **mockup\navigation.js, líneas 321–333**; checkout **mockup\carrito_y_confirmaci_n\code.html, líneas 282–290 y 354–362**; personalización **mockup\personalizar_hamburguesa\code.html, línea 346**; inventario **mockup\gesti_n_de_inventario\code.html, líneas 254–268**; editar **mockup\navigation.js, línea 253**; eliminar **mockup\navigation.js, líneas 293–296**.

Autorización: no se encontró inicio de sesión, verificación de identidad, guardia de rutas ni autorización en servidor. La navegación por rol solo lleva a páginas estáticas; ocultar botones o rutas del frontend no protege los datos.

04 Regla de seguridad y hallazgo

Regla indispensable

Todo valor controlable por una persona debe insertarse como texto, nunca interpretarse como HTML ejecutable.

Justificación, evidencia y estado

La regla evita que una entrada manipule la página o se interprete como contenido ejecutable. En inventario, los datos se obtienen mediante `FormData` y se interpolan en `row.innerHTML` antes de agregarlos al DOM. La regla **no se cumple en esa interacción**. Esto constituye un riesgo potencial de inyección DOM, sin evidencia de persistencia o propagación a otros usuarios.

Evidencia: mockup\gesti_n_de_inventario\code.html, líneas 262–267.

Duda técnica específica: ¿Los campos `name`, `category`, `stock` y `unit` del alta de inventario se insertan como texto seguro o se interpretan como HTML?

Se interpolan como HTML. Si se introduce contenido que el navegador interpreta como marcado, existe un riesgo potencial de inyección DOM, limitado en lo observado a la página abierta durante esa sesión. No se afirma XSS almacenado o remoto.

Recomendación concreta

Crear celdas con `document.createElement` y asignar entradas mediante `textContent`. Al implementar persistencia, validar tipos y reglas de negocio en el servidor; la validación del navegador no es frontera de seguridad.

Privacidad de pedidos y autorización futura

Delivery muestra un nombre y una dirección escritos en HTML estático. No es posible confirmar si son datos reales; si lo fueran, su publicación expondría información personal a visitantes del sitio. El frontend no restringe ese acceso. En producción, el servidor debe autorizar lecturas por titular y necesidad operativa (p. ej., repartidor asignado) y aplicar permisos por rol y por pedido.

Evidencia: mockup\panel_de_delivery\code.html, líneas 190–203.

Conclusión

Pedido conecta las vistas principales, pero sus campos y estados son inferidos. El workspace no contiene React ni backend, base de datos, autenticación o CRUD persistente. Hay operaciones visuales locales y una personalización en `sessionStorage`. Antes de usar datos reales se requieren autorización de servidor, protección de datos personales, validación de reglas de negocio y renderizado seguro. Confirmar que nombres y direcciones sean sintéticos antes de publicar.